

CSC432 – Information Security

1. Suppose that we have a Feistel Cipher where everything is the same except that there is only one encryption round (instead of 16). The hexadecimal key that is being used in the encryption round is 123456. Suppose that the hexadecimal input string for this round is ABCDEF12. Draw a comprehensive diagram which shows the complete working of encryption and decryption along with the inputs and outputs. You do not need to compute the bitwise operations. Similarly, abstract from the details of other functions.
2. How does AES not have a Feistel structure?
3. Briefly describe the 4 different stages of AES.
4. What are the 5 requirements to make a public-key crypto system a secure algorithm?
5. 8839 and 8849 are two prime numbers. Their product is 78216311. Find all the factors of 78216311.
6. Briefly describe the three major ways you can deter a timing attack on RSA.
7. $2323 \bmod 23 = 0$. Prove it using calculations.
8. What are the differences and similarities in conventional and public-key encryption?
9. Consider a scenario where you are being sent spam via email, SMS, etc. Which is the most expensive asset of yours that is being attacked?
10. Consider a scenario where you open your flex account but are also able to see other peoples' grades. Which kind of security violation is this?
11. Consider a scenario where you open your flex account but are not able to see your complete/correct attendance although the instructor can see the complete/correct attendance. Which kind of security violation is this?
12. Consider a scenario where try to log in to your flex account but are unable to due to a large number of students who are already logged in. Which kind of security violation is this?
13. Consider a scenario where you open your flex account and also able to see the page that used by the instructors to provide comments about the course to the HOD. The page is currently empty. Which kind of security violation is this?
14. What is the relationship between an attacker and an attack?
15. Suppose that you wrote a program which does not free memory (because you did not know that it could be an issue) after it is finished using it. Suppose this program is run on a server. With time, the server starts getting out of memory messages and crashes. Who is the attacker here?
16. How many keys are required for two people to communicate via a cipher?
17. What are the two main approaches we have studied to crack cipertext?
18. What are the two conditions for any encryption scheme to be computationally secure?
19. What are the two problems with one-time-pad encryption?
20. Construct a playfair matrix with the key **LARGEST**
21. Construct a playfair matrix with the key **OCCURRENCE**
22. Use the following two matrices to encrypt "Must see you over Cadogan West. Coming at once"

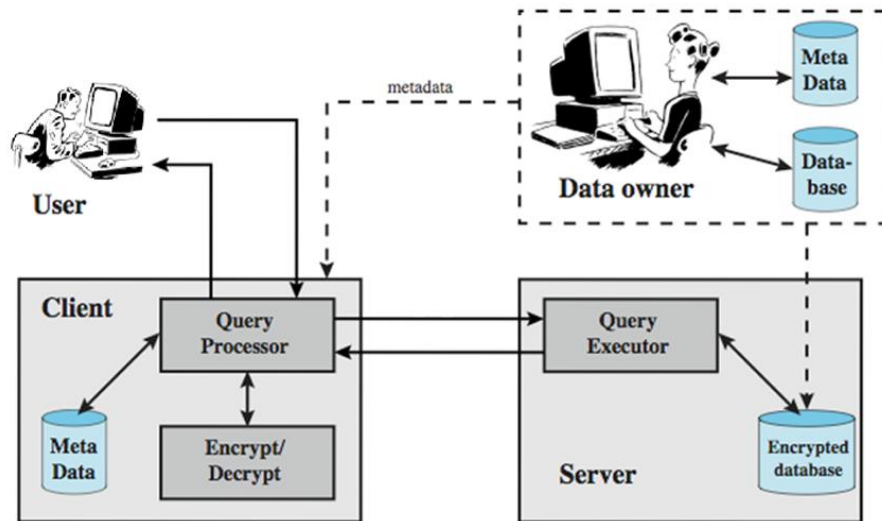
L	A	R	G	E
S	T	B	C	D
F	H	I/J	K	M
N	O	P	Q	U
V	W	X	Y	Z

M	F	G	I/J	K
U	N	O	P	Q
Z	V	W	X	Y
E	L	A	R	G
D	S	T	B	C

23. How many possible keys can a playfair cipher have? Ignore the fact that some keys may have identical results.

24. How many UNIQUE keys can a playfair cipher have?
25. Explain how longer passwords are more secure than shorter ones?
26. Parties A and B carry out a Diffie-Hellman Key Exchange, using a polynomial $p=33$ and generator $g=8$. Party A chooses a private key of 3, while B chooses 2. Show the equation for calculation of their public keys.
27. There are multiple ways to ensure the message authentication and one of them does not require any encryption. Draw a diagram that shows message authentication without using any encryption.
28. Principle of complete mediation cannot be applied 100%. Analyze the statement as correct or incorrect, and make your arguments.
29. Suppose you are writing an anti-virus software. You receive hundreds of samples of a single type of malware, but all samples look different. Identify kind of virus is that, and how can your anti-virus software spot it on running systems.
30. A company wants to securely communicate with their clients using public key cryptography. At the start of communication, both parties exchange their public keys. A client however is concerned that the key they received may belong to an attacker instead. What action should the company take that will make the client believe the received key?
31. Your company produces a 'medicine reminder' app for forgetful patients. Firstly, patients record their prescribed medication in the app. Later, the app creates notifications to remind the user whenever it's time to take the medicine. Upon taking a medicine, patient also records 'done' in the app. All data is saved on company servers – app only provides a front end interface. What are the confidentiality and availability threats for this app? Propose a solution for those threats.
32. In overall IT security management, human caused threats are the hardest to deal with due to direct physical access to resources. In your opinion, what could be the possible mitigation strategies in each of the following categories?
 - a) Employee screening and management
 - b) Technical controls
33. Consider the following scenario where we have the following four entities:
 - **Data owner:** organization that produces the sensitive data
 - **User:** that presents requests (queries) to the system.

- **Client:** Front-end that process the queries
- **Server:** that receives encrypted data from a data owner and makes them available for distribution to clients.

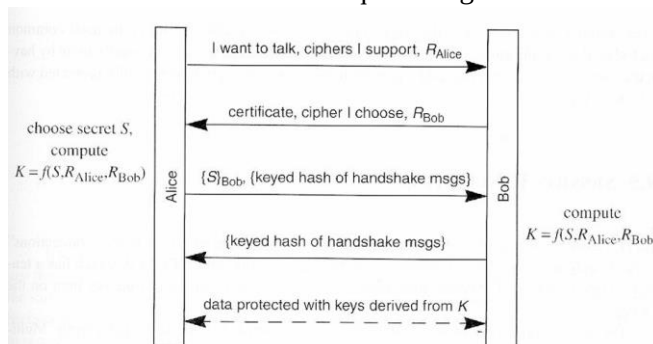


You have to answer the following question:

- Which level of encryption (complete DB, Record level or individual fields) will be better to avoid unauthorized access to data of other users without adding unnecessary overhead? Provide reasoning for your selection!
 - We can use both symmetric as well as Asymmetric encryption in this scenario. Provide pros and cons of each strategy!
 - Depict the complete process for the case where Asymmetric encryption has been used. How the data owner produces and saves encrypted records and how each user will access it. You can explain it by a use case considering couple of users and keys involved.
- 34.** In each of the following scenarios, identify which security design principle is followed OR violated. Elaborate your response.
- Complete mediation
 - Least Privilege
 - Economy of mechanism
 - Open Design
- The company behind Telegram messenger hired some brilliant cryptographers to design proprietary security protocols for secret chats.
 - Staff at an airline booking office is required to provide their password as well as scan their smart card before confirming a booking.
 - Program successfully opens a file in write mode, but after a few hours, writing data to file fails due to permission errors.
- 35.** Suppose you have received the following encrypted messages from the sender and you have been told that RSA algorithm is used to encrypt this information and the public key to decrypt the message is {7, 187}. Your task is to retrieve the original messages.
- C1 = 16
C2 = 24
- 36.** Analyze the following statements for correctness. Justify with arguments.
- Encryption with RSA is not vulnerable to man in the middle attacks.
 - A strong hash function like SHA-512 alone can compute the Message Authentication Code (MAC).

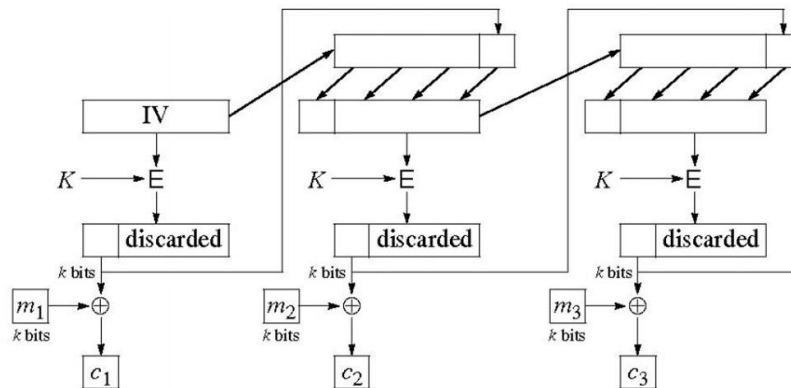
37. User A wants to download an operating system image from the vendor website. On downloading the OS image, the user should be able to assess the integrity and authenticity of the OS image in an optimal way. Draw a diagram to illustrate the process to ensure and validate integrity and authenticity of the OS image. Briefly describe each step of the process illustrated in your diagram.
38. Identify the kind of attacks in each of the following statements and identify at least a couple of reasons the people fall for that
- a) You receive a phone call. The caller claims that they are from a bank, and ask your debit card number and OTP for the purpose of account confirmation, otherwise your account will be blocked.
 - b) You tried to login to your flex account during which you ignored a warning displayed by the browser and later on you came to know that your login credentials have been stolen.
 - c) The outgoing network traffic of your system has suddenly increased and on diagnosis, you have identified that your system is constantly sending a specific request to a server.
39. We studied following security design principles: Least privilege, Failsafe defaults, Separation of privilege, Economy of mechanism, Psychological acceptability, Complete mediation, Least common mechanism. Analyze the following scenarios and identify, with reasoning, what security design principle is being applied? Also state what advantages are achieved due to that principle.
- a) Marketing staff do not have access to engineering design files.
 - c) Company database is protected by only one layer of encryption rather than two layers.
40. Describe the key development mechanism using RSA when the values of p and q are given to be 7 and 11 respectively? Although there are multiple options for choosing the encryption value 'e', let's choose 7 that fulfill the criteria and then find 'd' accordingly. You should provide all details and outcome should be written in the form of private and public keys. Demonstrate the working of your system by encrypting a number and then retrieving it back using decryption.
41. Show the process of Diffie-Helman key exchange using a prime 47 and generator 11. Suppose Alice chooses a secret 9 and Bob chooses 16.
42. Encrypt the text "voteforme" using Vigenère cipher with a key 245.
43. Biometric authentication sounds like a very reliable security measure. Despite that, it is not used everywhere. Discuss three reasons why.
44. Suppose an app is heavily used at your workplace. The app was written a long time ago in C language. Unfortunately the app source code was lost due to a hard disk failure. Your boss is concerned about some buffer overflow vulnerabilities that may exist in the app. What (technical) actions would you recommend to prevent buffer overflow exploits?
45. In the context of IoT security, discuss two examples for each of the following types of attacks:
- a) Physical attacks
 - b) Network attacks
46. What is a packet-filtering firewall? What are its pros and cons?
47. Consider a university database where all students' assessment marks are stored in one giant table: **Marks (StudentID, CourseID, Assignment, Quiz, Mid, Project, Final, Total)**
Now suppose this table is encrypted at the field level (i.e. every piece of data is individually encrypted). Analyze the following queries and argue whether these can be executed quickly or slowly on the encrypted database.
- SELECT StudentID, Assignment FROM Marks WHERE CourseID='CSC432' AND Assignment < 50;**
- SELECT Total FROM Marks WHERE StudentID=254 AND CourseID='CSC432';**
48. What is the concept of Perturbation? What are the different types of perturbation?

49. "In salted password storage, the salt should not be leaked to attackers in any case, otherwise user's password will be compromised." Discuss whether you agree or disagree with the statement.
50. Discuss how checking the Origin header can help in mitigating CSRF attacks.
51. What kind of obfuscation techniques is used by retro viruses to avoid detection and analysis?
52. Use the Rail Cipher to decrypt the following ciphertext, assuming a depth level of 3:
TPLEATA_NRM_ILRLCT_OKRSOUW_OE_UO
53. In the RSA algorithm, given that the $p = 61$ and $q = 53$. You need to calculate the following items:
1. The value of n .
 2. The totient $\phi(n)$.
 3. If the public exponent $e = 17$ private key exponent d .
54. Suppose Alice and Bob wish to perform Diffie Hellman key exchange. They agree on prime number $p = 11$ and generator $g = 6$. Alice chooses a secret 5, while Bob chooses 8. An attacker Mallory is listening to all of their communication. He chooses his own secret 4.
Show the calculation that proves that Mallory can perform a man-in-the-middle attack against Alice and Bob's key exchange.
55. Why is it not a good idea to do keyed hashing in this fashion: $h = H(k \parallel \text{message})$ i.e. the key placed at the start of the message and hashed.
56. During the establishment of SSL secure communication between a client and a server, the client says hello to the server and the server responds with the certificate that binds its identity to its public key. It may happen so that the server would send more than one certificate to the browser/client. Can you elaborate what other certificates the server would send to the client and what is their purpose?
57. If the Certification Authority server were to crash, will the network be disabled? If yes/no, why?
58. Draw the block diagram of a DES single round. Proper label the diagram.
59. Identify the type of malware in the following scenarios. State your reasons.
1. You visited a friend's house and connected your laptop to their Wi-Fi network. Without any further action on your part, the PC crashed due to malware attack.
 2. You obtained a cracked copy of Photoshop from an unknown website. It apparently works fine, but you notice that the computer has got very slow and laggy ever since.
 3. While browsing the Internet, following message suddenly pops up: ALERT. Your location is Lahore, Pakistan, and your activities are being tracked. To protect your privacy, get this VPN service.
60. The communication given below depicts how Alice and Bob would establish a secure SSL connection. Then answer the question given below.



1. How is Bob authenticating Alice? Explain with valid reason(s).

2. How is Alice & Bob computing the Keyed hash? Using the master key or pre-master key? Any ideas why use a specific one?
 3. What protocol was used in SSL to encapsulate packets from the application layer. Write its four types.
 4. Write down the number of keys generated in SSL v2. And v3. How are they created? What are they used for in v2 & v3?
- 61.** With the mode of operation given below, answer the question with reasons in not more than 2 lines each.



1. What is the name of this mode of operation?
 2. Identify if it is synchronous / self-synchronous / stream / block cipher & importantly why?
 3. What does one bit error in transmission results in? Explain your answer.
 4. Is random access possible? If yes/no, how/why?
 5. If the communicating parties use implicit IV which is generated using a complex proprietary method, what is the effect of a known-plaintext attack?
- 62.** Instead of using an explicit hashing function like SHA-1, MD5, SHA-2, why can't we use checksum along with a secret code added to it?
- 63.** We know that we can use symmetric encryption below to authenticate the other party, do you think hashing can be used in a similar way for authentication? If yes, how? If no, why? Graphical elaborations are always welcomed.
- 64.** We can create a MAC using an encryption algorithm as well. Why don't we use encryption instead of hashing to compute a MAC?
- 65.** What are the two main methods of integrity? Compare the two briefly.
- 66.** Alice and Bob wants to transfer data to each other. Give two suggestions of cryptographic functions usage by which they can achieve confidentiality, integrity & non-repudiation.
For simplicity, suppose the case in which only Alice is sending data to Bob and not vice versa.
- 67.** Consider a very simple hash function that requires the input to be in decimal digits. For hashing, it sums up all digits in the input and then performs a modulo 10 division, e.g. $H(2458) = 2+4+5+8 \bmod 10 = 9$
1. Does the above hash function meet 'preimage resistance' requirement?
 2. Does the above hash function meet 'collision resistance' requirement?
- 68.** List any two reasons for certificate revocation, what would happen if certificate was not revoked?
- 69.** Discuss any two problems with CSRL's.
- 70.** Applying Affine cipher, decrypt the following text when $a = 7$, $b = 5$
ICH OPIPUH JB RHI JS RZPU GZDHU
- 71.** Generate the first round key of DES using the following P-box, if the initial key is FF-FF-FF-FF-FF-FF-FF-FF in hexa-decimal

(Please write your answer in hexadecimal)

Permutation Choice 1							
57	49	41	33	25	17	9	
1	58	50	42	34	26	18	
10	2	59	51	43	35	27	
19	11	3	60	52	44	36	
63	55	47	39	31	23	15	
7	62	54	46	38	30	22	
14	6	61	53	45	37	29	
21	13	5	28	20	12	4	

Permutation Choice 2							
14	17	11	24	1	5	3	28
15	6	21	10	23	19	12	4
26	8	16	7	27	20	13	2
41	52	31	37	47	55	30	40
51	45	33	48	44	49	39	56
34	53	46	42	50	36	29	32

72. Apply a scenario of Diffie-Hellman protocol with $g=7$ and $p=11$. Assume, Alice picks 7 as her random number while Bob picks 8 as his random number. What will be the value of shared secret between Alice and Bob following the Diffie-Hellman message exchange?
73. Structuring RSA protocol with $p=7$ and $q=13$, estimate the key values and from all the possible key values figure out the three maximum values.

74. **A)** You have designed a new algorithm for checking message authenticity by message digest. According to the algorithm, we can add together the numeric values of the alphabetical index of the first letter of each word, where letter "A" has index 0 and "Z" has index 25. As an example, "I graduated from COMSATS" will produce MD 21(as I=8, G=6, F=5, C=2 and $8+6+5+2=21$). You then use this algorithm to generate the digest of the following message: "I insist staying in COMSATS". Your friend launched a birthday attack and found a second candidate message having same digest.

Can you identify/investigate the second message? Show your calculations.

B) You then change the algorithm by replacing ADD with MULTIPLY. However, now the number of candidate messages increase from the previous case. Can you identify/debate the reason, why?

C) You then change the algorithm described in part a) by adding the first and second letter from each word (For example, "Graduated from COMSATS" will produce 61, as G=6, R=17, F=5, R=17, C=2 and O=14 ($6+17+5+17+2+14 = 61$)). Can you analyze the effect of this modification on the strength of the algorithm by concluding whether the number of candidate messages will increase or decrease from the case in part a), why?

D) Explain how the public and private key of the sender and receiver will be used for the following:

	Confidentiality	Integrity	Authentication	Non-repudiation
Sender +				
Sender -				
Receiver +				
Receiver -				

75. Applying Affine cipher, encrypt the following text when $a = 11$ and $b = 4$

TEN MARKS IN THIS QUESTION

76. For AES, the first round four-word key is

2b	28	ab	09
7e	ae	f7	cf
15	d2	15	4f
16	a6	88	3c

a) Your task is to generate the first round key (Round constant is 01 in Hexa).

b) Execute one round of DES on the text "Security", where the round key for this round is "00-00-FF-FF-FF". S-boxes and P-box are given below

LE: SECU = 18-4-2-20 RITY=17-8-19-24

77. Consider CUONLINE system and discuss the concepts of confidentiality, integrity and availability.

78. You need to guess a password having the following characteristics:

- It may possibly consist of all the lower-case letters (A-Z)
- It may possibly consist of all the upper-case letters (a-z)
- It may possibly consist of all the digits (0-9).
- The length of the password is 7 characters.

How many combination you need to try through brute force in the worst case.

79. Apply a scenario of Diffie-Hellman protocol with $g=6$ and $p=13$. Assume, Alice picks 7 as her private number while Bob picks 8 as his private number. Now assume that Trudy launches a man in the middle attack and picks 6 as her private number. As you can guess that in this case, Alice and Bob will communicate through Trudy so please identify the value of shared secrets between Alice and Trudy as well as Bob and Trudy following the Diffie-Hellman message exchange.

80. For DES, we have the following bit-stream at the end of round key XOR operation. Calculate the output of the S-box substitution using the given S-boxes

110101 100101 101010 001001 100000 010000 011100 101001

81. Kerberos involves three two-message exchanges:

1. One between the client and the Key Distribution Center (KDC)
2. One between the client and the Ticket Granting Service (TGS)
3. One between the client and the server (S) chosen by the client.

In Kerberos v4, the initial communication between the client C and the KDC D goes like this:

1. C sends a ticket request containing C's name and a TGS's name T.
2. The KDC checks that both C and T are known to the system.
3. The KDC creates a ticket containing C's and T's names, C's network address, the current time, the lifetime of the ticket, and a session key KCT. This ticket is encrypted with T's secret key KDT known to both the key-distribution center D and the ticket-granting service T.
4. The reply to C consists of the ticket just described, T's name, the current time, the lifetime of the ticket, and the session key, all encrypted with C's secret key KC. To keep messages that are intended for one purpose from being mistakenly used for another, the plaintext of the encrypted reply contains a constant string "krbtgt" identifying this as a ticket-granting ticket.
5. The client decrypts the reply and saves the ticket for use.

Answer the following questions:

a) Explain briefly, in general terms, the purpose of each of the three exchanges (between the client and KDC, client and TGS, and client and S).

b) Assume that the user's password is not stored on the client machine, and the client's key KC is computed from the user's password by a known function. Why is Kerberos more convenient, for the human user, than a system in which the TGS is eliminated, and the client makes a Kerberos-style request to the KDC for each server connection?

c) A Kerberos realm consists of a KDC, a TGS, a number of clients sharing keys with the KDC, and a number of application servers sharing keys with the TGS. In cross-realm authentication, a client in one realm wishes to use a server in another realm. Explain briefly how Kerberos is used in cross-realm authentication (across two realms) and state what key(s) must be shared between the two realms.